Exercise 13

Ex. No.: 12

Detect Web Application Vulnerabilities using Various Web Application Security Tools.

Aim

Use OWASP ZAP to discover common web application vulnerabilities (XSS, SQLi, CSRF, insecure

cookies, broken auth, etc.)

Steps:

1. Use CLI tool Nikto

2. Nikto – CLI-based web server scanner that finds dangerous files and outdated software.

3. Nikto is a popular open-source web server scanner that performs comprehensive tests against web

servers for multiple items

4. nikto -h http://https://demo.testfire.net/login.jsp

Department of Computer Science and Engineering (Cyber Security)/CR23331

After Downloading the Windows(64) Installer of ZAP , run the setup

After which , access the zap application

In the manual Explore option , type the url to crawl.

Department of Computer Science and Engineering (Cyber Security)/CR23331

We can also use an option called client spider , just right click the specified url in the

sites tab and in the attack options , click client spider

Department of Computer Science and Engineering (Cyber Security)/CR23331

Then goto Alerts:

Department of Computer Science and Engineering (Cyber Security)/CR23331

Step 1: Initialization

- Install and launch chosen scanner.

- OWASP ZAP: Launch GUI, configure target domain.

Step 2: Run Scan

- Start scanning:
  - For ZAP, run active scan after spidering.

Step 3: Monitor

- Observe scan progression and any alerts or findings in real time.

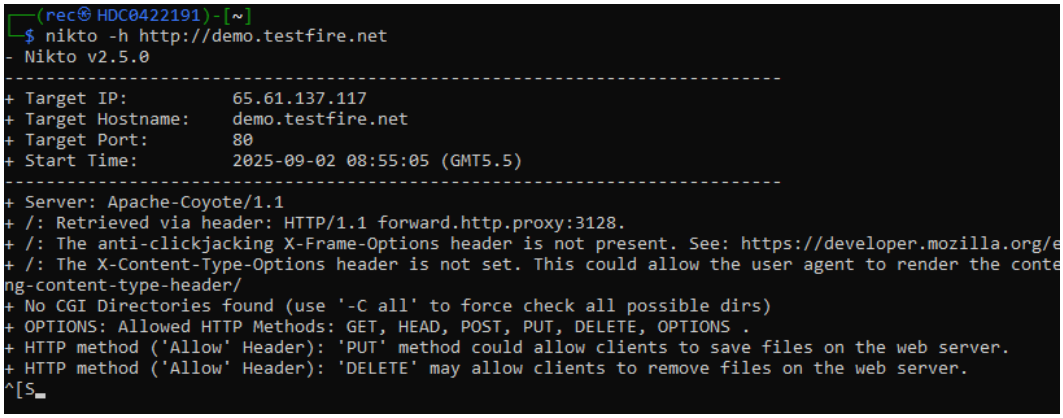
Step 4: Review Results

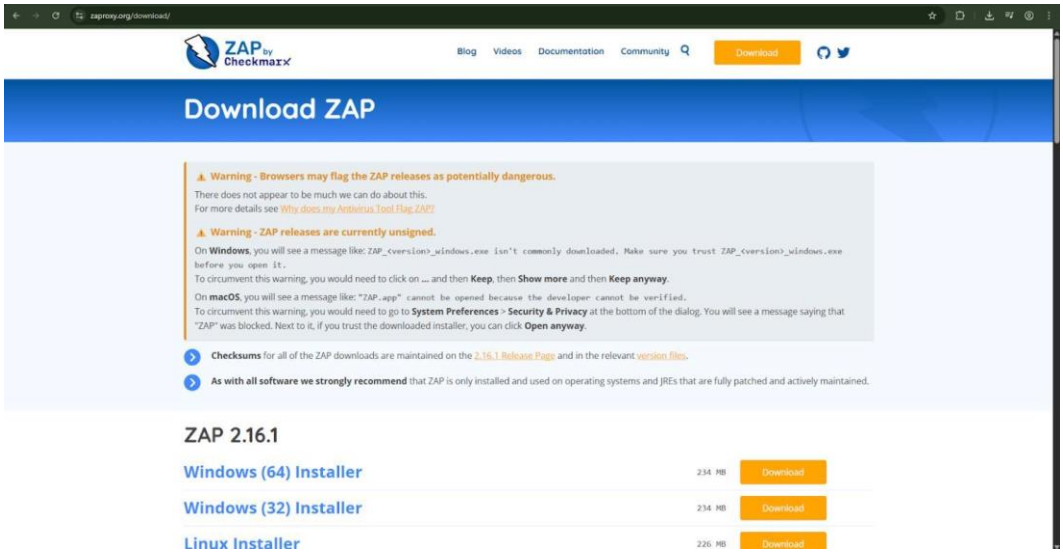
- ZAP: Review alerts pane (e.g., XSS, SQL injection, insecure cookies).

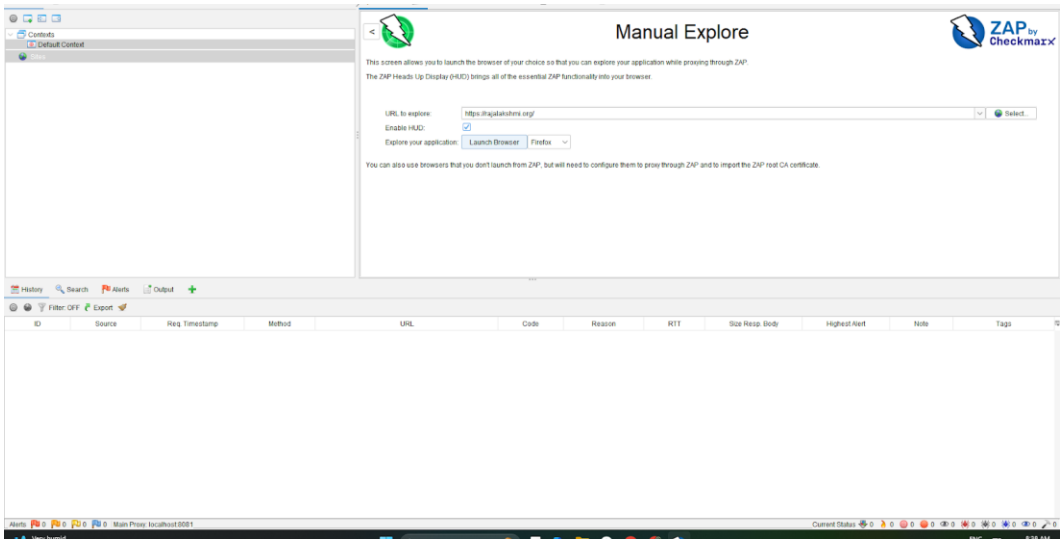
Result: Dynamic Application Security Testing (DAST) reveals various vulnerabilities.

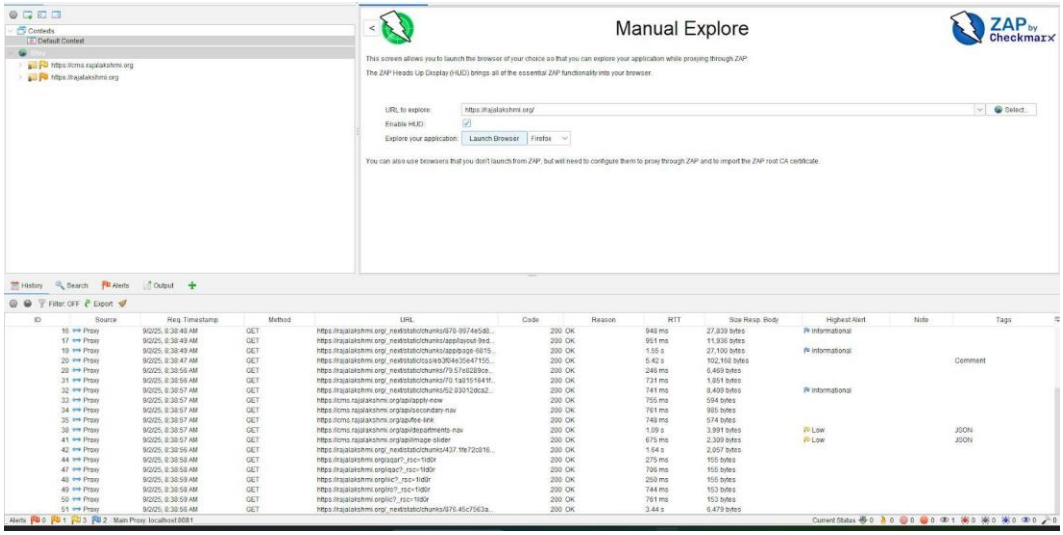
Department of Computer Science and Engineering (Cyber Security)/CR23331

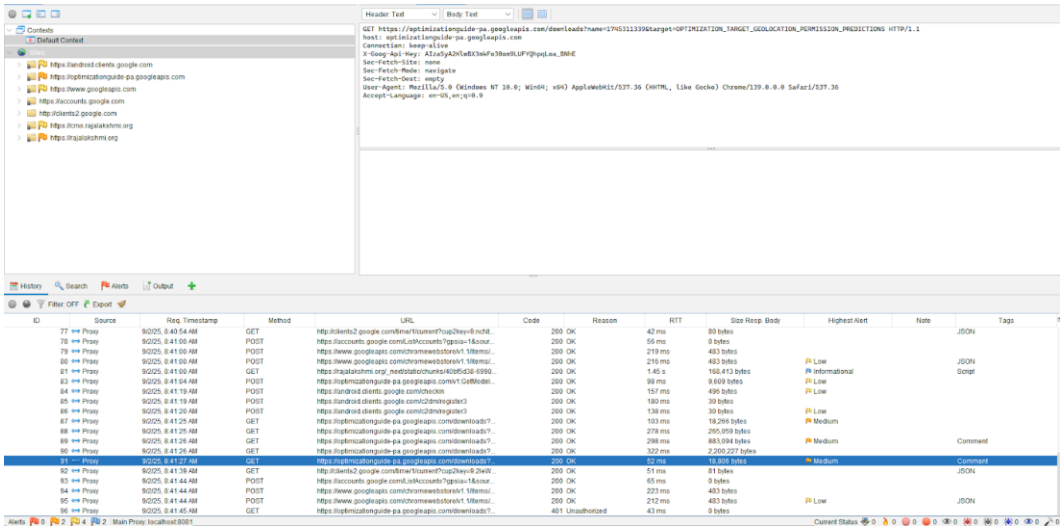
Screenshots

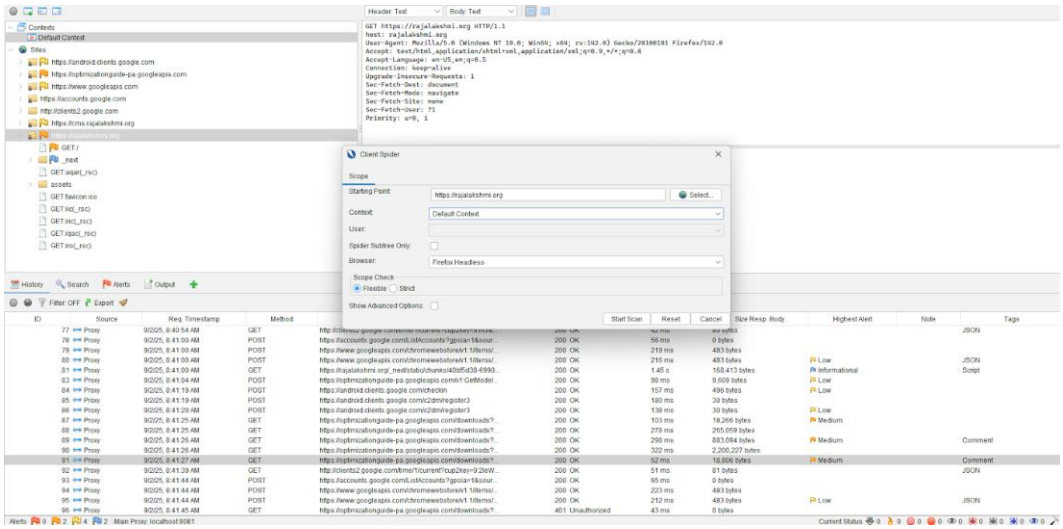


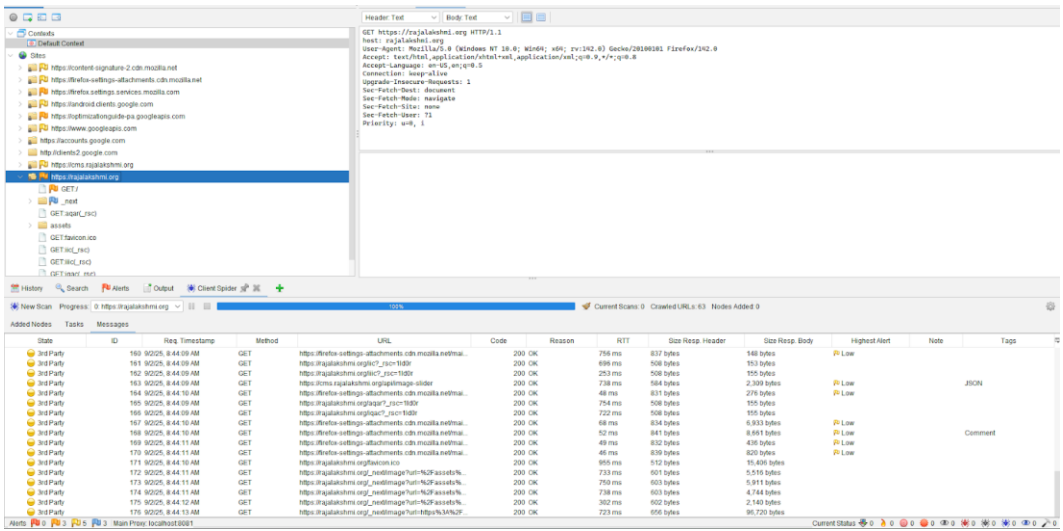

zaproxy.org/download/
ZAP by Checkmarx
Blog
Videos
Documentation
Community
Download
Download ZAP
Warning - Browsers may flag the ZAP releases as potentially dangerous.
There does not appear to be much we can do about this.
For more details see Why does my Antivirus Tool Flag ZAP?
Warning - ZAP releases are currently unsigned.
On Windows, you will see a message like: ZAP_<version>_windows.exe isn't commonly downloaded. Make sure you trust ZAP_<version>_windows.exe before you open it.
To circumvent this warning, you would need to click on ... and then Keep, then Show more and then Keep anyway.
On macOS, you will see a message like: "ZAP.app" cannot be opened because the developer cannot be verified.
To circumvent this warning, you would need to go to System Preferences > Security & Privacy at the bottom of the dialog. You will see a message saying that "ZAP" was blocked. Next to it, if you trust the downloaded installer, you can click Open anyway.
Checksums for all of the ZAP downloads are maintained on the 2.16.1 Release Page and in the relevant version files.
As with all software we strongly recommend that ZAP is only installed and used on operating systems and JREs that are fully patched and actively maintained.
ZAP 2.16.1
Windows (64) Installer
234 MB
Download
Windows (32) Installer
234 MB
Download
Linux Installer
226 MB
Download

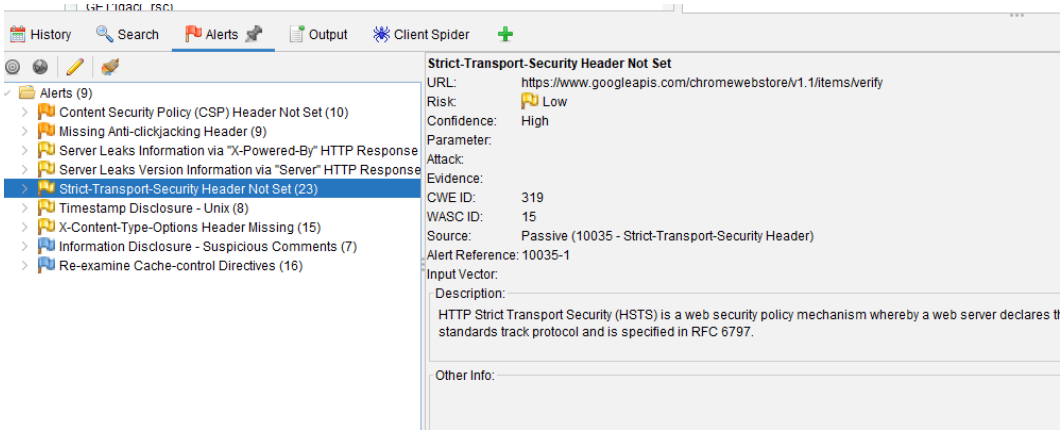

Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
Enable HUD:
Explore your application:
Launch Browser
Firefox
You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.

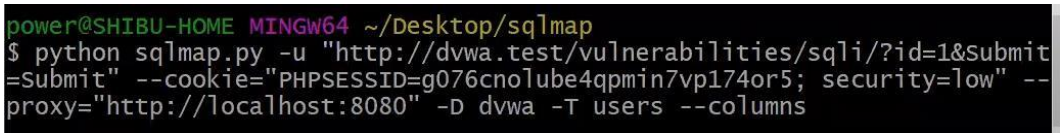

Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
Enable HUD:
Explore your application:
Launch Browser
Firefox
You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.

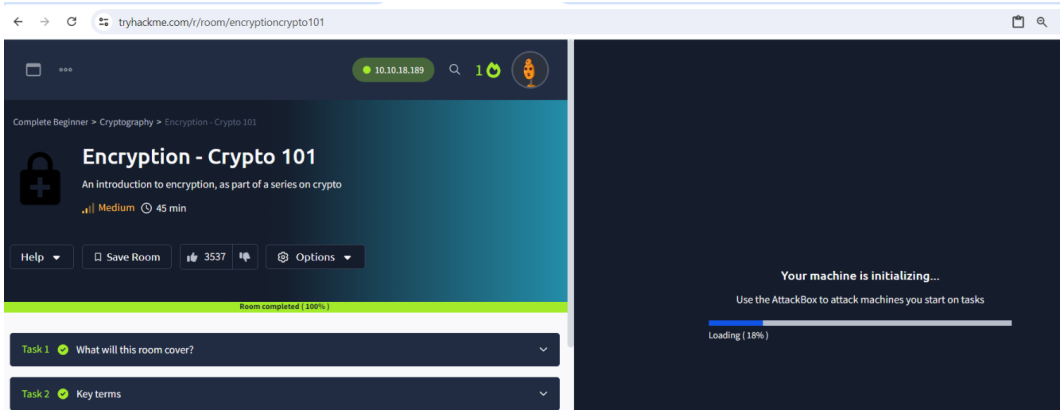


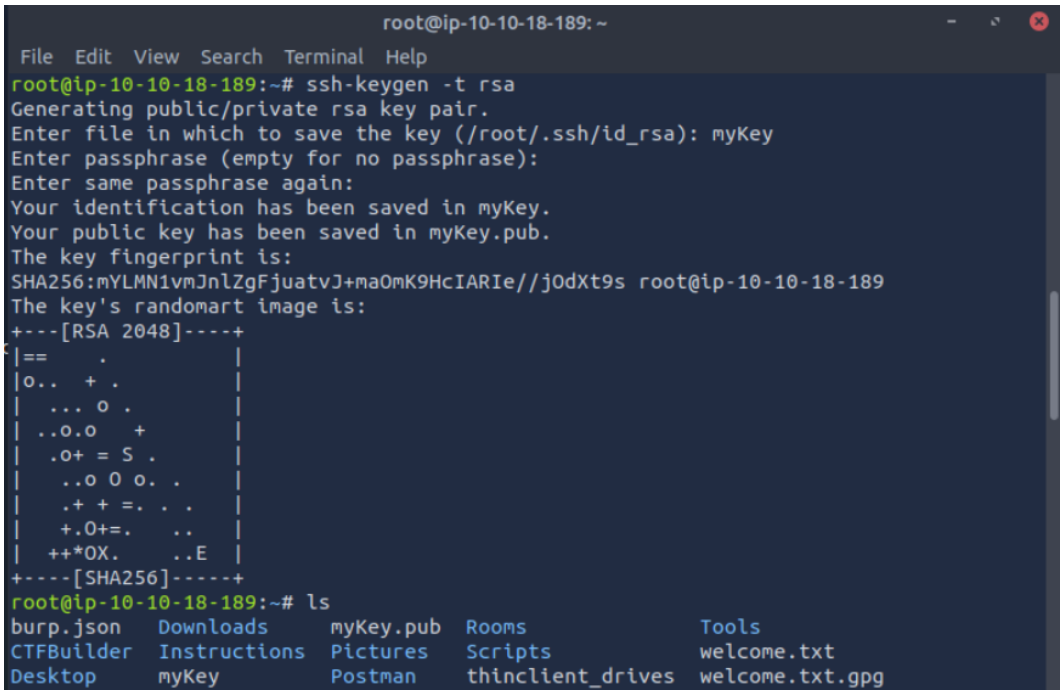





History
Search
Alerts
Output
Client Spider
Alerts (9)
Content Security Policy (CSP) Header Not Set (10)
Missing Anti-clickjacking Header (9)
Server Leaks Information via "X-Powered-By" HTTP Response
Server Leaks Version Information via "Server" HTTP Response
Strict-Transport-Security Header Not Set (23)
Timestamp Disclosure - Unix (8)
X-Content-Type-Options Header Missing (15)
Information Disclosure - Suspicious Comments (7)
Re-examine Cache-control Directives (16)
Strict-Transport-Security Header Not Set
URL: https://www.googleapis.com/chromewebstore/v1.1/items/verify
Risk: Low
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 319
WASC ID: 15
Source: Passive (10035 - Strict-Transport-Security Header)
Alert Reference: 10035-1
Input Vector:
Description:
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares th
standards track protocol and is specified in RFC 6797.
Other Info:


power@SHIBU-HOME MINGW64 ~/Desktop/sqlmap
$ python sqlmap.py -u "http://dvwa.test/vulnerabilities/sqli/?id=1&Submit
=Submit" --cookie="PHPSESSID=g076cnolube4qpmin7vp174or5; security=low" --
proxy="http://localhost:8080" -D dvwa -T users --columns


tryhackme.com/r/room/encryptioncrypto101
10.10.18.189
Complete Beginner > Cryptography > Encryption - Crypto 101
Encryption - Crypto 101
An introduction to encryption, as part of a series on crypto
Medium
45 min
Help
Save Room
3537
Options
Room completed (100%)
Task 1 What will this room cover?
Task 2 Key terms
Your machine is initializing...
Use the AttackBox to attack machines you start on tasks
Loading (18%)


root@ip-10-10-18-189: ~
File Edit View Search Terminal Help
root@ip-10-10-18-189:~# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa): myKey
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in myKey.
Your public key has been saved in myKey.pub.
The key fingerprint is:
SHA256:mYLMN1vmJnlZgFjuatvJ+maOmK9HcIARIe//jOdXt9s root@ip-10-10-18-189
The key's randomart image is:
+---[RSA 2048]----+
|==   . |
|o.. + . |
| ... o . |
| ..o.o   + |
| .o+ = S . |
| ..o O o. . |
| .+ + =. . . |
| +.O+=.   .. |
| ++*OX.   ..E |
+----[SHA256]-----+
root@ip-10-10-18-189:~# ls
burp.json Downloads myKey.pub Rooms Tools
CTFBuilder Instructions Pictures Scripts welcome.txt
Desktop myKey Postman thinclient_drives welcome.txt.gpg